

Préparation Réseau – Entretien Pentest (Synacktiv)

1. Que se passe-t-il quand tu tapes `https://www.synacktiv.com` dans ton navigateur ?

Étapes (avec couches OSI)

a. Résolution DNS (Couches 7, 3)

- Vérification du cache DNS local.
- Si manquant :
 - Requête au résolveur DNS.
 - Résolution hiérarchique : Root → TLD → Serveur autoritaire.
- Résultat : IP de `synacktiv.com`.

b. Ouverture de la connexion TCP (Couche 4)

- TCP 3-way handshake :
 - SYN → SYN-ACK → ACK.
- Port 443 utilisé (HTTPS).
- Connexion fiable établie.

c. Négociation TLS/SSL (Couches 6, 5)

- `ClientHello` : versions TLS, suites crypto, extensions.
- `ServerHello` : certificat, choix du cipher, clés publiques.
- Key exchange via ECDHE/RSA.
- Création d'une clé symétrique (AES).

d. Requête HTTP (Couche 7)

- Exemple :

GET / HTTP/1.1 Host: `www.synacktiv.com`

- La requête est chiffrée avec TLS.

e. Réponse serveur

- Données HTTP encapsulées dans TLS.
- Exemple :

HTTP/1.1 200 OK Content-Type: `text/html`

f. Fermeture de session

- Fermeture explicite (FIN/ACK) ou keep-alive.

2. Couches OSI – Résumé avec exemples

Couche	Nom	Rôle	Exemple
7	Application	Interface utilisateur	HTTP, DNS, SSH
6	Présentation	Chiffrement, encodage	TLS, Base64
5	Session	Gestion de session	SSL/TLS session

Couche	Nom	Rôle	Exemple
4	Transport	Transmission fiable	TCP, UDP
3	Réseau	Routage IP	IP, ICMP
2	Liaison de données	Transmission locale	Ethernet, ARP
1	Physique	Transmission électrique	Wi-Fi, RJ45, fibre

Remarque : TCP/IP simplifie OSI en 4 couches.

3. Différence entre TCP et UDP

Caractéristique	TCP	UDP
Connexion	Oui (handshake)	Non
Fiabilité	Oui (ACK, retransmission)	Non
Ordre garanti	Oui	Non
Vitesse	Plus lent	Plus rapide
Exemples	HTTP, SSH, FTP	DNS, SNMP, DHCP

4. Fonctionnement d'une requête DNS

1. Le client envoie une requête A ou AAAA à son résolveur DNS.
2. Si non résolu :
 - Contact root server . → TLD .com → Serveur autoritaire de `synacktiv.com`.
3. Le résolveur renvoie l'IP au client.
4. La réponse est mise en cache.

Commande utile : `dig www.synacktiv.com +trace`

5. TLS Handshake – Étapes détaillées

1. ClientHello

Le client envoie un message avec :

- Versions TLS supportées
- Suites cryptographiques proposées (ex : AES, ChaCha20)
- Extensions comme SNI (Server Name Indication)

2. ServerHello

Le serveur répond avec :

- La version TLS choisie
- Le cipher suite sélectionné
- Son certificat X.509
- Extensions acceptées

3. Vérification du certificat

Le client vérifie que le certificat est valide et signé par une CA reconnue.

4. Échange de clés (Key Exchange)

Utilisation d'algorithmes comme ECDHE ou RSA pour échanger une clé secrète de session.

5. Génération de la clé symétrique

Client et serveur génèrent une clé AES ou ChaCha20 partagée pour chiffrer la session.

6. Finished

Les deux parties s'envoient un message "Finished" chiffré prouvant que le handshake est terminé avec succès.

7. Communication chiffrée

Les données HTTP sont alors échangées de manière sécurisée.

6. Sniffer HTTPS avec Wireshark

- Le contenu HTTP est chiffré, donc illisible directement.
 - On peut observer :
 - Requêtes DNS en clair
 - Paquets du handshake TLS (ClientHello, ServerHello)
 - Adresses IP source/destination, ports
 - SNI dans le ClientHello (nom du site demandé)
 - Pour déchiffrer le contenu :
 - Avoir la clé privée du serveur (rare)
 - Ou utiliser la variable d'environnement `SSLKEYLOGFILE` sur le client pour enregistrer les clés de session TLS
-

7. ARP – Fonctionnement et attaques

Fonctionnement

- L'ARP permet de trouver l'adresse MAC correspondant à une adresse IP locale.
- Envoi d'une requête ARP broadcast ("Qui a cette IP ?")
- Réponse avec l'adresse MAC correspondante.

Attaque ARP spoofing

- Un attaquant envoie de fausses réponses ARP, associant sa MAC à l'IP d'un autre hôte (ex : passerelle).
- Cela permet d'intercepter ou modifier le trafic réseau (MITM).

Outils

- `arp spoof`

- bettercap
- ettercap

8. Outils de diagnostic réseau à maîtriser

Outil	Utilisation principale
tcpdump	Capture et analyse de paquets en ligne de commande
Wireshark	Analyse graphique et approfondie du trafic
dig, nslookup	Résolution et diagnostic DNS
ping, traceroute	Test de connectivité et parcours réseau
nmap, masscan	Scan de ports et identification de services
netstat, ss	Affichage des connexions et sockets réseau
lsof	Liste des fichiers ouverts et ports associés
curl, wget	Tester des requêtes HTTP/HTTPS
iptables, ufw	Configuration et gestion du firewall

9. Port scanning – Types et détection

Types de scans courants

- **TCP SYN scan** : envoi de SYN, détection ports ouverts sans établir la connexion complète.
- **TCP Connect scan** : complète la connexion TCP (SYN, SYN-ACK, ACK).
- **UDP scan** : envoi de paquets UDP, réponse ICMP indique port fermé.
- **Xmas scan / NULL scan** : paquets TCP avec flags inhabituels pour détecter certains comportements.

Détection

- IDS/IPS comme Snort ou Suricata analysent les logs et alertent sur les scans.
- Firewalls peuvent limiter ou bloquer les scans.
- Analyse manuelle avec `tcpdump` pour repérer les paquets SYN suspects :

```
“bash sudo tcpdump ‘tcp[tcpflags] & tcp-syn != 0’
```

10. Types d’attaques réseau fréquentes

- **MITM (Man-In-The-Middle)**
Interception et modification du trafic entre deux parties, souvent via ARP spoofing ou DNS spoofing.
- **Sniffing**
Capture passive de trafic réseau non chiffré pour récupérer des informations sensibles.
- **DoS / DDoS (Déni de service distribué)**
Saturation d’un service ou réseau par un volume élevé de requêtes ou paquets, rendant le service indisponible.
- **DNS poisoning (empoisonnement DNS)**
Injection de fausses entrées dans le cache DNS, redirigeant les utilisateurs vers de mauvaises adresses IP.

- **IP spoofing**
Usurpation d'adresse IP source dans les paquets pour masquer l'identité ou contourner des contrôles.
 - **TCP session hijacking**
Prise de contrôle d'une session TCP existante en volant ou en devinant des numéros de séquence.
 - **SMB relay**
Attaque spécifique aux protocoles Windows, où l'attaquant relaie des authentifications pour accéder à des ressources.
 - **DHCP starvation**
Inondation d'un serveur DHCP avec des requêtes pour épuiser la liste d'adresses IP disponibles.
-

11. Sécurité via HTTPS

1. **Chiffrement**
La communication est chiffrée grâce à TLS (protocoles comme AES ou ChaCha20), garantissant la confidentialité.
 2. **Authentification**
Le serveur s'authentifie avec un certificat X.509 signé par une autorité de certification reconnue.
 3. **Intégrité**
Les données sont protégées contre la modification grâce à des mécanismes d'intégrité comme les HMAC.
 4. **Perfect Forward Secrecy (PFS)**
Chaque session utilise une clé de chiffrement unique générée dynamiquement, empêchant qu'une clé compromise expose les sessions passées.
-

Commandes utiles à connaître

```
“bash # Résolution DNS dig synacktiv.com nslookup synacktiv.com
```

Connexion TLS brute (tester handshake et certificat)

```
openssl s_client -connect synacktiv.com:443
```

Requête HTTP avec verbose pour voir détails

```
curl -v https://synacktiv.com
```

Scan réseau de ports TCP SYN stealth

```
nmap -sS synacktiv.com
```

Capture de paquets réseau sur port 443 (HTTPS)

```
sudo tcpdump -i eth0 port 443
```